

# ATO package — documentation gap register and stubs

---

**What this document owns:** *missing documentation artifacts*. It is the register of documents an ATO reviewer would expect to find in this package and that do not exist yet, each with a priority, an owner, and a skeleton a future author can fill in.

**What it does not own:** security or technical findings. Those live in [poam.md](#), with their rationale in [security-assessment-2026-07.md](#). A gap here means "nobody has written this down"; a finding there means "the system does something that needs fixing." Where the two touch, this document cites the POA&M item rather than restating it.

The numbering (GAP-1 ... GAP-15) is preserved from the 2026-07 gap analysis that produced it, so cross-references from that analysis remain valid.

Contents:

- 1. [Closed by this change](#)
- 2. [Gap register](#)
- 3. [Organizational dependencies](#)
- 4. [Stubs](#) — GAP-4 through GAP-15
- 5. [Retiring a gap](#)

---

## 1. Closed by this change

| ID    | Artifact                                             | Closed by                                  |
|-------|------------------------------------------------------|--------------------------------------------|
| GAP-1 | SSP control-implementation matrix                    | <a href="#">control-implementation.md</a>  |
| GAP-2 | FIPS 199 categorization + information-type inventory | <a href="#">fips-199-categorization.md</a> |
| GAP-3 | Plan of Action and Milestones                        | <a href="#">poam.md</a>                    |

Two further documents landed in the same restructure and are **not** gaps: the point-in-time security assessment ( [security-assessment-2026-07.md](#) ) and the symptom-first failure-mode guide ( [../operations/troubleshooting.md](#) ).

GAP-14 (crypto module / FIPS validation) is **partially** closed — see its row.

---

## 2. Gap register

Priority: **P2** = commonly requested by an AO and cheap to write from material that already exists; **P3** = expected in a mature package, lower blocking risk.

Owner: **repo** = written in this repository by whoever maintains it; **operator** = the platform team running a deployment (deployment-specific content); **org** = only the deploying organization can produce it (§3).

| ID     | Artifact                                             | Priority | Owner           | Status           | Notes                                                                                                                                                                                                                                                                                                                                                                                                                 |
|--------|------------------------------------------------------|----------|-----------------|------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| GAP-4  | Incident Response Plan                               | P2       | repo + org      | Open             | Containment primitives all exist but are scattered; there is no "revoke this user now" procedure anywhere. Partial material: <code>om-runbooks.md</code> §9, <code>cost-controls.md</code> §5. Reporting timelines are an org input                                                                                                                                                                                   |
| GAP-5  | Contingency plan / DR with declared RTO and RPO      | P2       | repo + operator | Open             | Facts are settled ( <code>MultiAZ</code> default <code>true</code> , <code>BackupRetentionDays</code> default 14, <code>DesiredCount</code> default 2, single region); what is missing is the <i>declaration</i> plus a criticality table, the no-cross-region-DR acceptance, and a DR test record. Restore is teardown+restore — that is the RTO driver ( <code>om-runbooks.md</code> §8)                            |
| GAP-6  | Privacy analysis / PTA                               | P2       | repo + org      | Open             | The minimization work is already done and creditable (pgaudit excludes bind values; prompt/response content redacted from the activity stream by default — the <code>LOG_USER_PROMPTS=true</code> / <code>LOG_ASSISTANT_RESPONSES=true</code> opt-ins remove that minimization and must be declared in the analysis if enabled); the determination of whether a full PIA/SORN is required is the org privacy office's |
| GAP-7  | Rules of Behavior / acceptable use                   | P2       | repo + org      | Open             | The most conspicuous absence for a genAI ATO. Needs a user-facing section carried into <code>user-manual.pdf</code> as well as the ATO-facing document                                                                                                                                                                                                                                                                |
| GAP-8  | Continuous monitoring (ConMon) strategy              | P2       | repo + org      | Open             | No alarm ownership, review cadence, or reassessment trigger exists. Make an SNS subscription an explicit ATO condition — with <code>ALARM_SNS_TOPIC_ARN</code> empty, the alarms fire into nothing ( <code>monitoring-and-retention.md</code> §2)                                                                                                                                                                     |
| GAP-9  | Vulnerability and patch management                   | P2       | repo            | Open             | ECR <code>scanOnPush=true</code> is set in <code>scripts/common.sh</code> and documented nowhere. Also needs the severity→window SLA, the four-base-image + collector + plugin patch path, how <code>claude</code> binary CVEs are learned given locked auto-updates, an SBOM statement, and pen-test scope                                                                                                           |
| GAP-10 | External dependency / shared-responsibility register | P3       | repo + org      | Open             | Okta, Zscaler, Bedrock/GovCloud, Anthropic — boundary side, controls inherited, controls added here, failure mode, governing agreement. Partial: <code>conops.md</code> §8.2, <code>control-implementation.md</code> §2                                                                                                                                                                                               |
| GAP-11 | Configuration Management Plan                        | P3       | repo            | Open             | The <code>.claude/rules/*.md</code> files are the strongest CM evidence in the repository and are <b>invisible to a doc-only reviewer</b> — surfacing them is most of the work                                                                                                                                                                                                                                        |
| GAP-12 | Privileged-role inventory and separation of duties   | P3       | repo + org      | Open             | Consolidate the roles that today are scattered across <code>conops.md</code> §3: gateway user, portal admin, spend admin, Grafana admin, platform operator, and three break-glass paths. Deprovisioning is TTL-bounded — state the numbers                                                                                                                                                                            |
| GAP-13 | AI service governance                                | P3       | repo + org      | Open             | Data-use statement, model approval/change-control path, output-reliability caveat. §5 of <code>fips-199-categorization.md</code> holds the verified AWS data-handling facts; this gap is the <i>governance</i> wrapper around them                                                                                                                                                                                    |
| GAP-14 | Crypto module / FIPS 140 validation                  | P3       | repo            | Partially closed | <code>fips-199-categorization.md</code> §7 now states the position leg by leg, including two <b>NEEDS VERIFICATION</b> legs and the fact that no AWS FIPS endpoints are configured. What remains: a how-to-verify-on-a-live-listener procedure and resolution of the unverified legs                                                                                                                                  |
| GAP-15 |                                                      | P3       | repo + org      | Open             |                                                                                                                                                                                                                                                                                                                                                                                                                       |

| ID | Artifact                                               | Priority | Owner | Status | Notes                                                                                                                                                                                                                                                                   |
|----|--------------------------------------------------------|----------|-------|--------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    | Media protection, decommissioning and data destruction |          |       |        | Teardown deliberately retains a lot (log groups, both S3 archives, final RDS snapshot, ECR images, AMP workspace). Who authorizes destruction, and with what commands, is unwritten. Note the Object Lock deferral makes archives operator-deletable (accepted risk A1) |

### 3. Organizational dependencies

Artifacts and evidence that **only the deploying organization can produce**. They are listed here so their absence from this repository is understood as a boundary, not an oversight. `conops.md` §8.2 carries the *operational* prerequisites (certificate, DNS, Zscaler policy, Okta application and groups claim); this list is the *authorization-package* counterpart.

| Item                                                                            | Family     | Feeds                                      | Note                                                                                                                                           |
|---------------------------------------------------------------------------------|------------|--------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------|
| Security awareness and role-based training, including AI-usage training         | AT         | GAP-7, GAP-13                              | No AI-specific training content exists in-repo                                                                                                 |
| Personnel screening and position risk designations                              | PS         | GAP-12                                     | —                                                                                                                                              |
| Okta identity lifecycle (joiner/mover/leaver, MFA policy, session policy)       | AC-2, IA-2 | GAP-4, GAP-12                              | Deprovisioning latency in this system is bounded by session/token TTL, not by an Okta revoke ( <code>control-implementation.md</code> AC-2(3)) |
| Enterprise agreements — Okta, Zscaler, AWS                                      | SA, CA-3   | GAP-10                                     | Including which party holds which support/escalation path                                                                                      |
| SOC/SIEM onboarding and incident reporting timelines                            | IR         | GAP-4, GAP-8                               | Three log groups are flagged for SIEM ingestion but no subscription is created by the templates                                                |
| Penetration testing scope, schedule and authorization                           | CA-8, RA-5 | GAP-9                                      | —                                                                                                                                              |
| An SNS alarm topic <b>with subscribers</b> ( <code>ALARM_SNS_TOPIC_ARN</code> ) | SI-5, IR-6 | GAP-8                                      | The stacks create no topic. Empty parameter = alarms exist, nobody is notified. Recommend making this an explicit ATO condition                |
| Data-owner determination on prompt content classes                              | RA-2       | <code>fips-199-categorization.md</code> §8 | The single decision that can move the whole categorization                                                                                     |

### 4. Stubs

Each stub gives the proposed path, a one- or two-line scope statement, the inputs a future author should start from, and the section headers to fill. They are skeletons deliberately — writing the content is the work, and writing it *speculatively* would violate the repo's never-invent rule.

## GAP-4 — Incident Response Plan

*Proposed path:* docs/operations/incident-response.md *Scope:* how a suspected compromise, misuse, or data-exposure event on this deployment is detected, triaged, contained and reported. Not a general org IR plan — the org's plan is the parent, and this is the system-specific annex. *Inputs:* om-runbooks.md §9 (alarm response) and §7 (secrets/break-glass); cost-controls.md §5 (fail-closed incident); monitoring-and-retention.md §3 (evidence locations); conops.md §6.2 (degraded modes); org reporting timelines (§3 above).

```
## 1. Scope and relationship to the organizational IR plan
## 2. Detection sources
    (the four alarms; SIEM subscriptions; user reports; diagnostics)
## 3. Severity triage and declaration criteria
## 4. Containment actions, by scenario
    ### 4.1 Compromised or misused user account
        (Okta group removal / session revoke — state the TTL bound honestly)
    ### 4.2 Compromised admin or spend-admin capability
    ### 4.3 Gateway compromise suspected
        (desired-count 0; ALB rule removal)
    ### 4.4 Credential or key exposure
        (which secret, which rotation runbook, which service roll)
    ### 4.5 Runaway cost / abuse
        (spend clamp; org-wide cap)
## 5. Evidence map — what to collect, from where, before it ages out
## 6. Eradication and recovery
## 7. Reporting handoff — who, by when, with what content [org input]
## 8. Post-incident review and this document's update trigger
```

## GAP-5 — Contingency plan (RTO / RPO)

*Proposed path:* extend docs/operations/om-runbooks.md §8, or a new docs/ato/contingency-plan.md if the AO expects a standalone artifact. *Scope:* declared recovery objectives per component, the criticality that justifies them, and the record that a restore has actually been rehearsed. *Inputs:* om-runbooks.md §8 (backup/restore posture and the teardown+restore constraint); greenfield-deployment.md (the rebuild path); the parameter defaults cited in the register row above.

```
## 1. Criticality and mission impact statement
## 2. Component criticality table
    (RDS store, gateway service, ALB/cert, observability, portal)
## 3. Declared RTO and RPO, per component, with justification
## 4. Backup posture (cite om-runbooks §8; do not restate the numbers)
## 5. Recovery procedures by scenario
    ### 5.1 Task/service failure          ### 5.2 AZ failure
```

```
### 5.3 Data corruption or loss      ### 5.4 Whole-account rebuild
## 6. Accepted risk – single region, no cross-region DR
## 7. DR test record: date, scenario, result, defects raised
```

## GAP-6 — Privacy analysis / PTA

*Proposed path:* docs/ato/privacy-analysis.md *Scope:* what personal data the system collects, why, how it is minimized and retained, and whether a full PIA or SORN is required — the last being the org privacy office's determination, not this document's. *Inputs:* fips-199-categorization.md §2 (information types IT-3, IT-5, IT-6, IT-7); monitoring-and-retention.md §3 (retention); the minimization facts (pgaudit log\_parameter=0; prompt/response content redacted from the activity stream by default — conditional on LOG\_USER\_PROMPTS and LOG\_ASSISTANT\_RESPONSES staying off).

```
## 1. Purpose and determination sought
## 2. Personal data collected, by element
    (identity attributes; usage attributed to a named user; command and
    tool content; prompt content when Bedrock logging is enabled)
## 3. Purpose and legal/administrative basis for each element
## 4. Minimization already implemented
## 5. Retention and disposal (cite monitoring-and-retention §3)
## 6. Access, sharing and SIEM routing
## 7. Notice to users – where it is given
    (cross-reference the Rules of Behavior, GAP-7)
## 8. Determination: PTA only, or full PIA / SORN required [org]
```

## GAP-7 — Rules of Behavior / acceptable use

*Proposed path:* docs/ato/rules-of-behavior.md, plus a user-facing section in docs/operations/client-config.md Part I so it is carried into docs/generated/user-manual.pdf. *Scope:* what a developer may and may not put into a prompt, what is logged and attributable to them, and the standing of model output. The most conspicuous absence in a genAI authorization package. *Inputs:* fips-199-categorization.md §8 decisions 1 and 10; the audit surfaces in conops.md §5.4; the managed tool-deny policy in client-config.md §6.

```
## 1. Applicability and acknowledgement
## 2. Permitted data classes in prompts [org decision – placeholder]
## 3. Prohibited content
    (credentials and keys; PII; classified; export-controlled;
    third-party material the org may not disclose)
## 4. Monitoring and attribution notice
    (usage metrics, activity stream when enabled, prompt logging when
    enabled; that records are attributable to the named Okta user)
## 5. Model output is not authoritative – review obligations
## 6. Client configuration: what may not be changed, and why
```

```
## 7. Reporting suspected exposure
## 8. Consequences of violation [org]
```

## GAP-8 — Continuous monitoring strategy

*Proposed path:* a new section in `docs/operations/monitoring-and-retention.md` (preferred — it already owns the alarm and retention facts), or a standalone `common-strategy.md`. *Scope:* who watches what, how often, and what forces a reassessment. Today nobody is named anywhere. *Inputs:* `monitoring-and-retention.md` §1–§2; `om-runbooks.md` §9 and §9a; the open detection findings in `poam.md` (registered there as prior AUD-1 ... AUD-5).

```
## 1. Alarm ownership and response SLA, per alarm
## 2. SNS subscription as an ATO condition
## 3. Log-review cadence, per audit surface
    (pgaudit; portal audit; admin_audit; activity stream; ALB logs)
## 4. Compensating operator cadence where automation is absent
    (e.g. failed_translations checks – see poam.md, prior AUD-2)
## 5. Re-mirror / rebuild / patch cadence
## 6. Quarterly access review (Okta groups → the four gated surfaces)
## 7. Annual reassessment and the events that force an earlier one
## 8. Metrics reported upward, and to whom [org]
```

## GAP-9 — Vulnerability and patch management

*Proposed path:* a new section in `docs/operations/om-runbooks.md` (it already owns §5 and §6, the update runbooks). *Scope:* how vulnerabilities in each component class are learned about, prioritized and remediated — including the awkward one, the pinned `claude` client whose auto-updates are deliberately disabled. *Inputs:* `scripts/common.sh` (`ensure_ecr_repo sets scanOnPush=true` — currently undocumented); `om-runbooks.md` §5, §6; `scripts/mirror/mirror-base-images.sh`; `poam.md` (its supply-chain rows, prior SUP-1 ... SUP-5).

```
## 1. Scanning coverage – what is scanned, what is not
## 2. Severity to remediation-window SLA
## 3. Patch paths by component
    ### 3.1 Four container base images    ### 3.2 ADOT collector
    ### 3.3 Grafana + pinned plugin        ### 3.4 RDS engine
    ### 3.5 The claude client binary
        (locked auto-updates; requiredMinimumVersion as the ratchet;
        publish the installer before raising the floor)
## 4. Emergency patch path
## 5. SBOM statement – what exists, what does not
## 6. Penetration testing scope and schedule [org]
```

## GAP-10 — External dependency / shared-responsibility register

*Proposed path:* a new `conops.md` §8.4. *Scope:* one row per external party, stating what it provides, which side of the boundary it sits on, what this system inherits, what this system adds, and what happens when it fails. *Inputs:* `control-implementation.md` §2 (the inheritance table is the seed); `conops.md` §6.2 (failure modes) and §8.2; `greenfield-deployment.md` Phase 0.

```
## 8.4 External dependencies and shared responsibility
  (table: party | boundary side | provides | inherited controls |
    controls added here | failure mode | agreement/owner)
  Parties: AWS GovCloud; the landing zone; Okta; Zscaler; Anthropic
  (build-time only – the client fleet does not contact it at runtime)
```

## GAP-11 — Configuration Management Plan

*Proposed path:* `docs/ato/configuration-management.md` *Scope:* what the baseline is, how it changes, and what automated gates enforce that. The single most valuable thing this document can do is surface `.claude/rules/*.md`, which encode the repo's real change discipline and are invisible to anyone reading only `docs/`. *Inputs:* `.claude/rules/process.md`, `cloudformation.md`, `scripts.md`, `security.md`, `offline-build.md`; `.github/workflows/tests.yml`; `control-implementation.md` §6.

```
## 1. Configuration items and the baseline
  (templates; deploy.env; pinned image digests; grafana-plugin.pin)
## 2. Change authorization and review
  (the multi-agent adversarial review rule; make test green)
## 3. Automated CM gates
  (tests/cfn cfn-guard rules, one line each: what would go red)
## 4. Immutability and replacement protection
  (ECR IMMUTABLE; stack policies; deletion protection)
## 5. Day-one decisions that cannot be changed in place
  (RDS CMK; AMP CMK; exported names)
## 6. Emergency change and the post-hoc revert obligation
  (cost-controls.md §5.2 fail-closed flip is the worked example)
## 7. CI inventory
```

## GAP-12 — Privileged-role inventory and separation of duties

*Proposed path:* extend `docs/ato/conops.md` §3. *Scope:* one consolidated table of every privileged capability, how it is granted, who approves, how it is revoked, and how long revocation takes. *Inputs:* `conops.md` §3.1–§3.6; `architecture.md` §4 and §6; `cost-controls.md` §2 and §7; `control-implementation.md` AC-2(3), AC-5.

```

### 3.7 Privileged roles – grant, approval, revocation
  (table: role | capability | granting mechanism | approver |
    revocation action | revocation latency)
  Rows: end-user developer; portal admin; spend admin; Grafana admin;
  platform operator; break-glass RDS master; break-glass spend-admin
  keys; break-glass Grafana bootstrap admin
### 3.8 Separation of duties statement
### 3.9 Okta lifecycle as an organizational dependency

```

## GAP-13 — AI service governance

*Proposed path:* a new `conops.md` §9. *Scope:* the governance wrapper around the AI service itself — where prompt data goes, how a model gets approved or changed, and what users are told about output reliability. *Inputs:* `fips-199-categorization.md` §5 (verified AWS data-handling facts — cite them, do not re-derive) and §6; `om-runbooks.md` §6 (model/image change path); `conops.md` §8.1 (model availability constraints).

```

## 9.1 Data-use statement
  (cite fips-199-categorization.md §5; re-verify before resubmission –
    Bedrock retention semantics change)
## 9.2 Model approval and change control
  (who approves a model ID change; the deploy path; the duplicate-ID
    guard; verify IDs against the Bedrock console first)
## 9.3 Authorization scope of the configured models [org confirm]
## 9.4 Output reliability and human-review expectations
## 9.5 Prohibited uses (cross-reference the Rules of Behavior, GAP-7)

```

## GAP-14 — Crypto module / FIPS validation (*partially closed*)

*Proposed path:* extend `docs/ato/architecture.md` §9, referencing `fips-199-categorization.md` §7 rather than duplicating it. *Scope:* what remains after §7 — a live-verification procedure and resolution of the two unverified legs. *Inputs:* `fips-199-categorization.md` §7 (the leg-by-leg table and its citations); `cloudformation/02-gateway.yaml` (TlsSecurityPolicy).

```

## Remaining work
- Procedure: confirm the negotiated policy on the live listener
  (describe-ssl-policies / connection logs) and record the result
- Resolve: which crypto module terminates the per-task TLS legs
- Resolve: the client-side (Claude binary) TLS module
- Decide and record: whether AWS FIPS service endpoints are required
  (none are configured today – see §7 row 4)
- Note for the A0: the ALB backend policy is not operator-selectable

```

## GAP-15 — Media protection, decommissioning and data destruction

*Proposed path:* extend `docs/operations/om-runbooks.md §13` (teardown). *Scope:* what survives a teardown by design, who authorizes destroying it, and the commands that do so. *Inputs:* `om-runbooks.md §13`; `architecture.md §9`; the `DeletionPolicy: Retain` posture carried by all nine log groups (see `control-implementation.md AU-9`); accepted risk A1 (Object Lock deferred).

```
## 13.x Retained artifacts after teardown
    (log groups; activity archive; prompt-log bucket; ALB-logs bucket;
    final RDS snapshot; ECR images; AMP workspace; portal artifacts)
## 13.y Destruction authorization – who approves, on what record
## 13.z Sanitization procedures, per artifact class
## 13.aa Note: no Object Lock, so archives are operator-deletable – this
    cuts both ways (easy destruction, weak tamper-evidence)
```

---

## 5. Retiring a gap

When a gap's artifact is written:

1. Move its row from §2 into §1 with the path of the document that closed it.
2. Delete its stub section.
3. Update any `ato-package-gaps.md GAP-n` cross-reference in `control-implementation.md` to point at the new document instead.
4. If closing the gap changed a control's status, update `control-implementation.md` in the same change.

New *documentation* gaps are added here with the next free ID. New *findings* go to [poam.md](#) — do not add them here, and do not restate POA&M items in a stub.